GENAI BASICS • LESSON 15 • MODULE 4: IDEA TO PRODUCT

Responsible AI

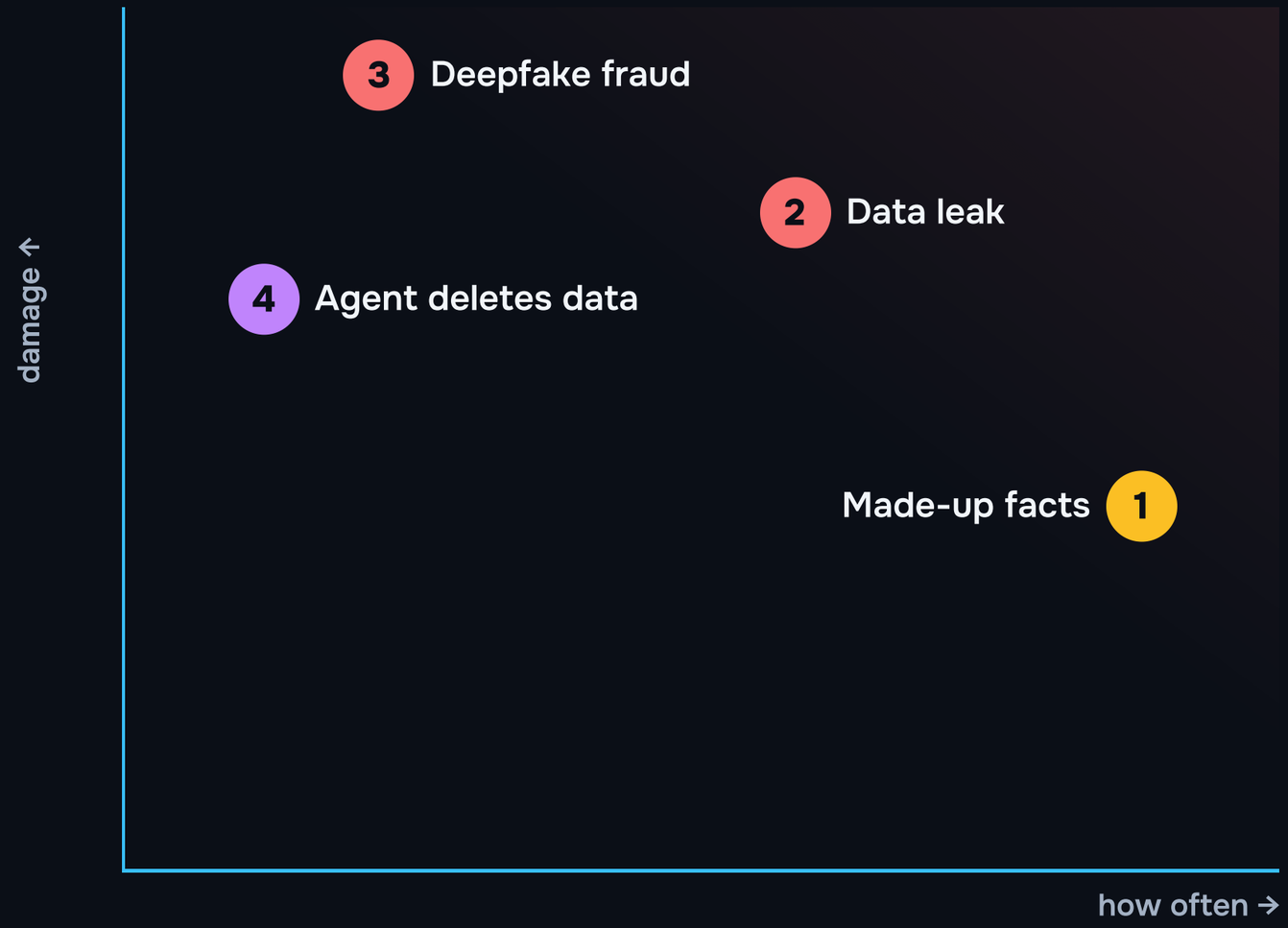
Errors, leaks, deepfakes and laws: how to use AI at work without doing harm

Real cases from 2023–2026, data rules, the EU AI Act, Uzbekistan, Kazakhstan, Russia. Data as of October 2026.



RISK MAP

Four main AI risks at work: what happens often and what costs a lot



1. **Made-up facts** (hallucinations) — every day
2. **Data leak** — one pasted file
3. **Deepfake fraud** — rare, but millions
4. **An agent deletes data** — in seconds

RISK 1

The model confidently makes things up — a human must check the answer

45%
of AI assistant answers about news had a significant issue (EBU/BBC, 22 broadcasters, October 2025)

2 190
court decisions worldwide where AI-invented citations were found (D. Charlotin's database, October 2026)

$5 000
fine for lawyers in Mata v. Avianca (US, 2023): they cited cases ChatGPT made up

1. **AI answered** — confident and fluent — not a sign of truth
2. **Find the source** — the law, report, company site, document
3. **Check the details** — numbers, names, dates, links, quotes
4. **You send it** — and you are responsible for it

Rule: check numbers, names, links, laws and quotes from an AI answer against the original source. The sender is responsible, not the AI.

RISK 2

A leak starts with one pasted file: decide in advance which data may go where

Public
website texts, published documents
→ any AI tool

Internal
plans, internal emails
→ company-approved AI only

Confidential
customer personal data, passwords, contracts
→ never in AI chats without explicit approval

Samsung, 2023: engineers pasted company source code into ChatGPT; the company then temporarily banned generative AI tools on work devices.

Grok, 2025: the share button made chats public — Forbes found over 370,000 conversations in Google.

PLANS

Same model, different rules: personal and business plans treat data differently

- **ChatGPT Free / Plus / Pro**
  your chats may be used for training unless you switch it off: Settings → Data controls
- **Claude Free / Pro / Max**
  since August 2025 you choose; if allowed, kept for up to 5 years
- **ChatGPT Business / Enterprise**
  does not train on company data by default
- **Claude for Work · Gemini in Workspace**
  does not train on company data by default

Work data goes only into the company's business account. A personal ChatGPT or Claude is not for customer documents, even a paid one.

RISK 3

A video call with “the CFO” can be fake: verify money requests through another channel

$25 M

Arup, Hong Kong, 2024: an employee transferred money after a video call where the “CFO” and colleagues were deepfakes

Call back on a known number, not the one in the email or chat.

A code word for urgent money requests in your family and team.

Urgency and secrecy are the main sign of fraud.

1. **A call from “the CFO”**
   face and voice are familiar — it may be a deepfake
2. **Urgent and secret**
   “transfer today, tell no one”
3. **Stop**
   end the call, pay nothing
4. **Call back yourself**
   on a known number, or ask for the code word

RISK 4

Excessive agency: an agent does whatever it has rights to — even if you did not want it to

9 seconds

PocketOS, April 2026: a Cursor agent found a stray access key in a file and deleted the production database and its backups; about 30 hours of downtime

2025

Replit, July: an agent deleted a production database during a declared code freeze

1. **A task for the agent** — an ordinary request in Cursor
2. **A key in a file** — the agent found access nobody meant to give
3. **Database and backups deleted** — in 9 seconds, without asking a human
4. **~30 hours of downtime** — customers without the service

Rules from L11–L12: least privilege · no production passwords or keys near the agent · human confirmation for deletion and money · backups kept separately.

OWASP

The OWASP Top 10 for AI apps: the four that affect everyone

OWASP is a non-profit community of security specialists.

LLM01

Prompt injection

someone else’s text commands the model (L11)

LLM02

Sensitive information disclosure

the model reveals what must not be seen

LLM06

Excessive agency

the agent got too many rights

LLM09

Misinformation

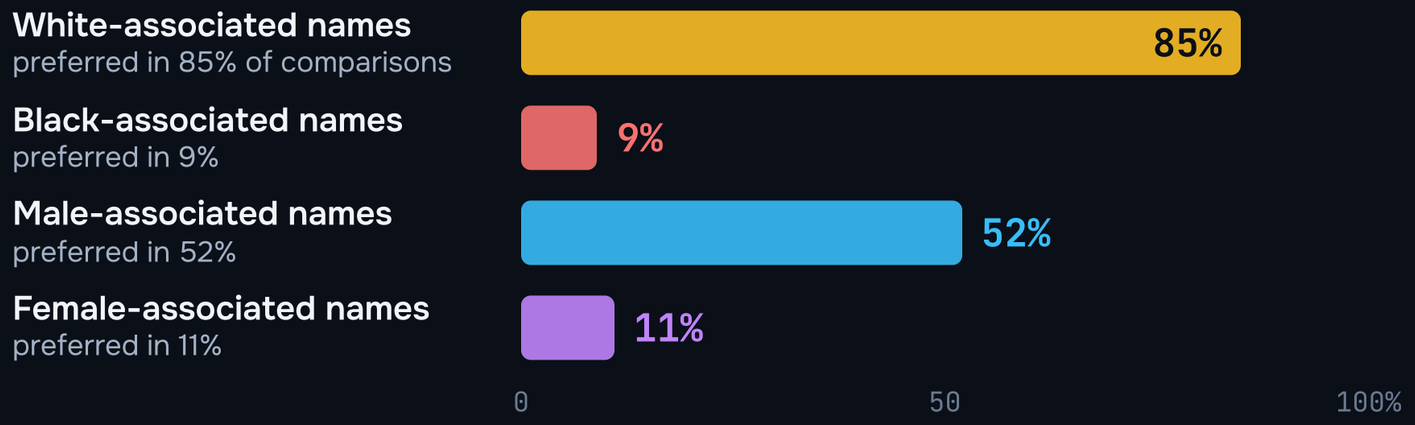
confident fabrications

> The 2025 list is the common language of developers and security teams. A separate list for agents came out in December 2025.

BIAS

AI repeats the biases in its data: CVs that differed only in the name were ranked differently

University of Washington study (2024): AI ranked CVs that differed only in the name.



Rule: decisions about people — hiring, credit, dismissal — AI may prepare, but a human decides. Laws are moving the same way (slides 11–12).

LABELLING

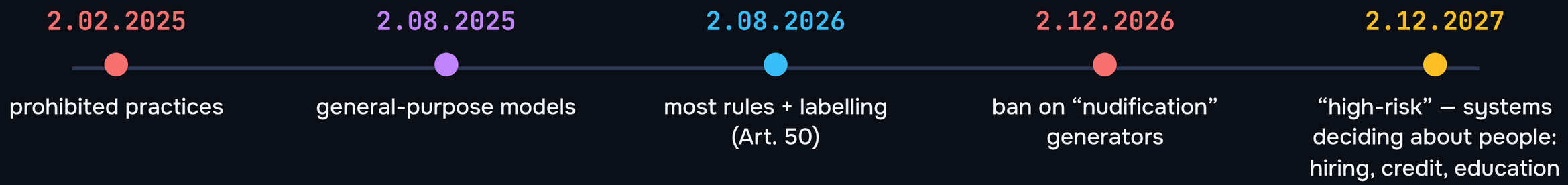
Laws require labelling AI content, and technology helps: invisible marks and signatures

- **SynthID (Google)**
  an invisible mark in pixels, sound and text; you can check an image in the Gemini app
- **C2PA Content Credentials**
  signed “who made it, with what” metadata; lost on a screenshot
- **No mark ≠ made by a human**
  and a mark does not prove the content is true

Labelling is already required: China (from 1.09.2025), Kazakhstan (from 18.01.2026), the EU — AI Act Art. 50 (from 2.08.2026). **Russia** — rules for large platforms from 1.03.2027.

EU AI ACT

The EU AI Act applies in stages — most of it is in force, high-risk rules from 2027



Fines: up to €35M or 7% of turnover for prohibited practices; up to €15M or 3% for the rest, including labelling.

It also applies to companies outside the EU if their AI is used in the EU.

OUR REGION

Uzbekistan, Kazakhstan and Russia have already passed AI laws or amendments — with a lot in common

- **Uzbekistan**
  law ZRU-1115 (January 2026): decisions on people's rights must not rest on AI alone; AI strategy to 2030
- **Kazakhstan**
  Law "On Artificial Intelligence" (from 18.01.2026): manipulation ban, labelling
- **Russia**
  a framework AI law (from 1.09.2026), labelling rules for large platforms from 1.03.2027
- **US · UK**
  no single law; separate state and sector rules

In common: a human is accountable for decisions and personal data is protected; Kazakhstan already requires labelling AI content, Russia from 2027.

This is an overview, not legal advice: check details with your company's lawyers.

BREAK

5 minutes: recall what you pasted into AI this week

05:00

Next: team rules, an exercise, homework.

TEAM RULES

AI rules for a team fit on one page: four points

Approved tools

a list of AI allowed for work, and business accounts

Data traffic light

what may be pasted, what only into work AI, what never

A human checks

numbers, links, decisions about people — before sending

Labels and incidents

label AI content; where to report a leak

> This is also the homework template.

EXERCISE

Exercise: is this OK — and what to do differently?

- **“I’ll paste a client contract into ChatGPT to summarise it”**
  OK? what to do differently?
- **“I’ll generate an image for the company’s social media post”**
  OK? what to do differently?
- **“AI will sort the CVs and I’ll invite the top five”**
  OK? what to do differently?
- **“The CEO asks on a video call to pay an invoice urgently”**
  OK? what to do differently?

> Answer each case in the chat: “yes”, “yes, but…” or “no”. Walk-through after the discussion.

HOMEWORK

Homework: one-page AI rules for your team

1. Take your team and 3 real AI tasks
2. A list of approved tools and accounts
3. A data traffic light with examples from your work
4. What a human checks and how to label AI content
5. What to do on a leak or a deepfake call

```
L15_homework/
├─ ai_rules.md
└─ README.md
```

> You may ask AI for a draft — but check and complete it yourself.

SUMMARY

Lesson summary

Check

numbers, links, quotes — against the source

Data traffic light

work data only into work AI

A human decides

about people, money, deletion

Label AI

deepfakes and AI content — where the law or platform requires

Next, L16: agentic software development — how agents write code and how to steer them safely.